

Security and Governance Note

Project 2: Startup Screening Workflow. Deterministic scoring on AWS Bedrock Flows.

Cindy Moncada | AI Solutions Architect

This note records the security and governance controls applied to the reference implementation, the reasoning behind each, and its current status. This is a reference implementation, not a production system; the final section states plainly what is deliberately not yet in place.

1. PII handling: mask on both input and output

Control: A Bedrock Guardrail detects personal information (name, email, phone, address) and masks it on both the input to the model and the output from it.

Rationale: The screener evaluates the business, not the people, so founders' personal details should never reach the model in the clear. Masking on input keeps PII out of processing; masking on output is defense in depth against anything echoed or missed. Masking rather than blocking is deliberate: it anonymizes the submission while still allowing the assessment to run, whereas blocking would reject a valid startup just for naming a founder.

Status: Implemented on both directions.

2. Content safety filter

Control: The same guardrail applies content filters (hate, violence, misconduct, and similar) at a medium threshold on inputs and outputs.

Rationale: A light backstop against abusive or harmful submissions. It is not the main event for a screening tool, but it is cheap insurance and part of a complete guardrail posture.

Status: Implemented as a secondary layer.

3. Data residency

Control: The Flow, the model, and the guardrail all run on AWS in Europe (Frankfurt), eu-central-1, inside the EU.

Rationale: Consistent with the EU-residency posture that runs through the portfolio. The Frankfurt regional endpoint keeps inference in the EU, accepting a roughly 10% cost premium over the global endpoint as the price of that residency.

Status: Implemented, with the residency-versus-cost trade-off documented in the cost model.

4. Least-privilege execution role

Control: The Flow runs under a scoped AWS execution role that grants only the permissions the Flow's nodes need to call the model and the guardrail.

Rationale: The workflow should be able to do its job and nothing more. A narrowly scoped role means a compromise cannot reach unrelated resources. This mirrors the managed-identity, least-privilege posture from Project 1.

Status: Implemented (role auto-generated and scoped to the Flow's nodes).

5. Determinism and inspectability

Control: The system is a deterministic workflow, not an autonomous agent, producing a structured, banded assessment for every input.

Rationale: For a screening decision, repeatable and inspectable output is a governance property, not just a design preference. The same input yields the same structured result, which can be reviewed, audited, and challenged, and the output is written for a human reviewer who makes the final call.

Status: Implemented and validated by the ten-case evaluation harness (100% band match).

6. Deliberately out of scope for this reference implementation

The following are not implemented, by scope:

Network isolation: the Flow uses standard Bedrock endpoints; production would consider VPC endpoints and private networking.

Submission audit logging: individual submissions and assessments are not persisted to an audit trail; production would log decisions for review and appeal, with retention rules.

Enforced human-in-the-loop: the tool is designed to feed a human reviewer, but nothing in the system forces a human gate before a recommendation is acted on; production would make that gate explicit.

Bias and fairness review: the rubric and model outputs have not been formally tested for bias across founder or company characteristics, which a production screening tool affecting real funding decisions would require.

Prompt-injection hardening: submissions are treated as data, but the system has not been hardened against adversarial inputs designed to manipulate the score.

Why state this: naming what is absent is the senior move. For a reference implementation, a clear line between built and deferred is more credible than implying completeness, and the bias and human-in-the-loop items in particular are exactly what a responsible production version of a funding-screener would have to address.